

ANALISIS Y PLANIFICACIÓN DEL PENTEST

Vanessa Valderrama

Hacker Women Council – Ethical Hacking

OBJETIVOS DEL PENTEST.

1. Identificar si existen vulnerabilidades en la gestión de sesiones y autorización que permitan a un usuario ver, modificar o acceder a pedidos o información personal de otras cuentas.
2. Probar la resistencia y seguridad del flujo de comercio electrónico y autenticación. Evaluar la exposición frente a vulnerabilidades críticas de web.
3. Proporcionar un informe claro y clasificado por criticidad que ayude al equipo de desarrollo y directivos a entender los riesgos reales para la operación y reputación de la empresa, guiando la remediación.

ALCANCE.

- Si se evaluará (sistemas o elementos incluidos en el alcance):
 - Aplicación web pública de comercio electrónico de Aurora Market
 - Panel web de administración/empleados.
 - Sistema interno de la página (Mecanismos de autenticación y control de sesiones).
- Fuera del alcance (elementos que no serán evaluados):
 - Redes sociales oficiales de la empresa.
 - Equipos personales de los empleados.
 - Correos electrónicos del personal.

- Proveedores externos.

AUTORIZACIÓN Y CONDICIONES.

- Permisos requeridos:
 - Documentos legales donde Aurora Market autorice las pruebas pertinentes.
 - Acuerdos de confidencialidad para cuidar y no revelar información privada.
- Condiciones acordadas:
 - No interrumpir deliberadamente el funcionamiento de la plataforma.
 - No afectar información real de los clientes.
 - Realizar las pruebas durante horarios de menor actividad.
 - Documentación detallada.

TIPO DE PENTEST.

GRAY-BOX

Aurora Market no entrego toda la información técnica ni el código interno de la página web. Sin embargo, si dio cierta información básica; el funcionamiento de la aplicación web, la existencia de una base de datos y los diferentes tipos de usuarios (clientes y administradores). Teniendo esta información parcial se puede simular ser un cliente promedio, navegar dentro de estos entornos para posteriormente, descubrir posibles áreas de mejora.

PLANIFICACIÓN.

- Objetivos:
Definir las metas concretas: entender la falla reportada de visualización cruzada y evaluar la resistencia de la tienda
- Alcance:
Establecer las URL exactas, formularios y endpoints que se evaluarán, descartando expresamente redes sociales y equipos de empleados.
- Permisos y condiciones:

Firmar el documento de autorización y convenir el horario nocturno/de baja actividad para las pruebas.

- Metodología a utilizar:

Elegir un marco de trabajo estándar de seguridad web (como OWASP) para asegurar que no se omita ninguna prueba esencial.

- Recopilación de información previa:

Conseguir la dirección web y creación de cuentas para realizar pruebas.

- Recursos necesarios:

Preparar los programas de evaluación y equipos físicos que se usará.

- Programación del pentest:

Elaborar un cronograma detallando los días y las horas exactas en que se realizarán las pruebas y cuándo se entregará el reporte final

FASE DEL PENTEST.

- Reconocimiento:

Mapear de forma pasiva y activa la superficie web de Aurora Market: descubrir tecnologías del servidor web, frameworks utilizados, endpoints ocultos, rutas del panel de administración y estructura de peticiones HTTP sin enviar tráfico invasivo.

- Análisis de vulnerabilidades:

Buscar debilidades en los mecanismos de entrada y autenticación. Se revisará si las contraseñas viajan seguras, si las cookies de sesión son manipulables y, especialmente, cómo la web identifica los pedidos de cada cliente.

- Explotación:

Intentar confirmar las sospechas mediante pruebas controladas y no destructivas. Si al cambiar el identificador del cliente se logran ver los datos de otra persona, se comprueba una falla de Control de Acceso. También se intentará acceder al panel de administración sin los permisos debidos.

- Post-explotación:

Analizar el impacto real de lo descubierto. Observar qué tan lejos podría llegar un atacante real una vez dentro; a la información a la que podría acceder (tarjetas, direcciones, teléfonos) y los privilegios que podría obtener, cuidando de no dañar información real.

- Informe:

Escribir un documento final que resuma las fallas encontradas y explique cómo solucionarlas.

INVESTIGACIÓN.

Metodología elegida: OWASP WSTG (Guía de Pruebas de Seguridad para Aplicaciones Web).

¿Por qué?

Para el desarrollo de la investigación metodológica, la opción más adecuada es la OWASP. Esta guía representa el estándar a nivel internacional para evaluar la seguridad en aplicaciones y servicios web, ofreciendo un marco de trabajo integral que combina técnicas de análisis para auditar plataformas interactivas. Esta metodología resulta especialmente útil y precisa para este proyecto debido a que el incidente reportado se origina en el comportamiento de la propia aplicación web frente a diferentes usuarios. La WSTG estructura sus procedimientos en categorías exhaustivas que atacan directamente los focos de riesgo del comercio electrónico, tales como la gestión de identidad, la autenticación, el manejo de sesiones, la validación de entradas de datos y, fundamentalmente, las pruebas de autorización y control de acceso.

Al aplicar este marco de trabajo, el equipo auditor puede ejecutar pruebas metódicas diseñadas para verificar si el sistema valida correctamente que quien solicita ver un pedido o un perfil realmente sea el dueño legítimo de esa información. Esto permite recrear de manera controlada el escenario del fallo reportado por el cliente, identificar si se trata de una referencia directa insegura a objetos o de una falla en los privilegios entre roles de usuario y administradores. Se evaluarían principalmente tres ítems; el control de acceso y visualización de datos; separación de privilegios; y autenticación y gestión de sesiones.